SYNTHETIC DRAFT · NOT CLIENT-READY

Customer portal assessment

web.lab.example · 192.0.2.20/32

RPT-121 · frozen 2026-11-02T10:23:02.568Z

Local UI scenario. No real security assessment or model analysis was performed.

7.1 Executive Summary

Assess the authorized customer portal. Discover services, investigate web configuration, and prepare a report with supporting evidence.

2 candidate findings included; 2 await analyst review; 1 false-positive dispositions excluded. No exploit is confirmed. Business exposure and impact are analyst scenario context when supplied; otherwise they remain unknown.

Draft rationale: Preview pending review and incomplete scenario coverage.

7.2 Assessment Methodology

Scope v1: web.lab.example / 192.0.2.20/32; TCP 80, 443. Exclusions: db.lab.example. ROE: Illustrative ROE-AST-021. Budget: 2 requests/s, 120s deadline; validity 3 Nov 2026, 17:23.

Method: request → reasoned proposal → approval → execution/import → normalization/correlation → risk review → snapshot. All executions below are simulated; historical import is not a live scan.

RUN-014 · Nmap · succeeded · action ACT-016 · approval APR-016
Started 2026-11-02T02:47:00Z; finished 2026-11-02T02:48:00Z; artifacts ART-101.

IMP-008 · Greenbone · succeeded · action none (import) · approval none (import)
Started 2026-11-02T02:55:00Z; finished 2026-11-02T02:55:01Z; artifacts ART-102.

RUN-108 · OWASP ZAP · succeeded · action ACT-017 · approval APR-106
Started 2026-11-02T10:23:01.089Z; finished 2026-11-02T10:23:02.189Z; artifacts ART-110.

7.3 Severity Distribution

Included candidate counts, not confirmed exploit counts: Critical 0 · High 0 · Medium 2 · Low 0 · Informational 0 · Unknown 0.

Review ranking: review-order-v1 combines source severity, analyst exposure/exploitability/impact context and explicit unknowns; stable finding ID breaks ties. Unknown severity is unresolved, not zero risk. Exposure, exploitability and impact are unknown unless explicitly reviewed with a rationale; calibrated confidence is not established. CVSS is unknown unless a supported vector/source exists.

1. FND-115 · Resolve context · Medium · Cookie missing Secure attribute
2. FND-116 · Resolve context · Medium · Missing Content-Security-Policy header

7.4 Detailed Vulnerability Findings

FND-115 · Cookie missing Secure attribute

Affected asset: web.lab.example/login. Synthetic scanner indication; source text is illustrative and may require application context.

Severity: Medium (Synthetic source indication). CVSS: Unknown — no supported vector/source. CVE: Not established. CWE: Not established.
Confidence: Uncalibrated source indication. Technical validation: suspected. Analyst disposition: needs_review.
Exposure: Unknown — authorized lab only. Exploitability: Not validated.
Review rationale: Not yet reviewed.
Priority: Resolve context · review-order-v1: source Medium; exposure unknown; exploitability unknown; impact unknown. Source confidence remains uncalibrated.
Context rationale: Not recorded.

Evidence: OBS-112 → ART-110 → site[0].alerts[1].instances[0]
SYNTHETIC-zap.json · source severity Medium (illustrative); confidence Uncalibrated source indication · synthetic fixture
Observed 2026-11-02T10:23:02.189Z; ingested 2026-11-02T10:23:02.189Z
`SHA-256 6c1e1edbdc8e197a29868948897f7c1daff5c4814da312eef875a0859cedb7a9`

FND-116 · Missing Content-Security-Policy header

Affected asset: web.lab.example/admin. Synthetic scanner indication; source text is illustrative and may require application context.

Severity: Medium (Synthetic source indication). CVSS: Unknown — no supported vector/source. CVE: Not established. CWE: Not established.
Confidence: Uncalibrated source indication. Technical validation: suspected. Analyst disposition: needs_review.
Exposure: Unknown — authorized lab only. Exploitability: Not validated.
Review rationale: Not yet reviewed.
Priority: Resolve context · review-order-v1: source Medium; exposure unknown; exploitability unknown; impact unknown. Source confidence remains uncalibrated.
Context rationale: Not recorded.

Evidence: OBS-113 → ART-110 → site[0].alerts[0].instances[1]
SYNTHETIC-zap.json · source severity Medium (illustrative); confidence Uncalibrated source indication · synthetic fixture
Observed 2026-11-02T10:23:02.189Z; ingested 2026-11-02T10:23:02.189Z
`SHA-256 6c1e1edbdc8e197a29868948897f7c1daff5c4814da312eef875a0859cedb7a9`

7.5 Impact and Remediation

FND-115 · Cookie missing Secure attribute

Impact: Unknown — business context required. Not validated.

Recommendation: Review whether this cookie is sensitive; set Secure and enforce HTTPS.

Evidence references: OBS-112. Remediation reference: OWASP Secure Cookie Attribute. No CVE/vendor advisory is asserted.

FND-116 · Missing Content-Security-Policy header

Impact: Unknown — business context required. Not validated.

Recommendation: Test a restrictive Content-Security-Policy in staging, then deploy and monitor violation reports.

Evidence references: OBS-113. Remediation reference: OWASP Content Security Policy. No CVE/vendor advisory is asserted.

7.6 Assessment Limitations

No model, real scanner execution, native import parser, authenticated approval, durable audit, database persistence or server PDF integration. All raw bytes/checksums belong to synthetic fixtures. A checksum establishes fixture byte identity only. No findings does not establish security.

Draft acknowledgement: Preview pending review and incomplete scenario coverage..

Unresolved: All candidate findings reviewed — 2 pending finding review(s).

Unresolved: Live integrations and server PDF verified — Đang triển khai. This prototype can produce a local draft preview only.

Run limitations: No failed attempt in this scenario; live coverage remains unverified..

Human decisions: ACT-017: Executed; Authorized bounded lab baseline; HTTP service basis reviewed.; outcome succeeded | ACT-016: Executed; Synthetic approval: bounded service discovery within the example ROE.; outcome succeeded.

Assessment timestamps: 2026-11-02T10:23:02.568Z report generation; OBS-201: observed 2026-11-02T02:48:00Z, ingested 2026-11-02T02:48:00Z | OBS-203: observed 2026-10-29T08:21:00Z, ingested 2026-11-02T02:55:01Z | OBS-111: observed 2026-11-02T10:23:02.189Z, ingested 2026-11-02T10:23:02.189Z | OBS-112: observed 2026-11-02T10:23:02.189Z, ingested 2026-11-02T10:23:02.189Z | OBS-113: observed 2026-11-02T10:23:02.189Z, ingested 2026-11-02T10:23:02.189Z.

Tool status: Nmap, ZAP and Greenbone Planned; Nessus, Nikto, Burp and Metasploit Unsupported. Three working integrations/imports are not proven.

Appendix · Excluded candidates

FND-042 · Missing Content-Security-Policy header
False positive disposition: Sample only; exclude from included candidate count for this review.. Original observations retained: OBS-203, OBS-111.

Appendix · Evidence manifest

ART-101 · SYNTHETIC-nmap.xml · 322 bytes · synthetic
SHA-256 2de8e619b462c7d43d88c08c508466bc265b11f57690249de86ca1b162df6637

ART-102 · SYNTHETIC-greenbone.xml · 380 bytes · synthetic
SHA-256 dbe83d083d7a1880b6b2ef93deac93566861a5f933cec6853f866fefc2a6af0c

ART-110 · SYNTHETIC-zap.json · 995 bytes · synthetic
SHA-256 6c1e1edbdc8e197a29868948897f7c1daff5c4814da312eef875a0859cedb7a9